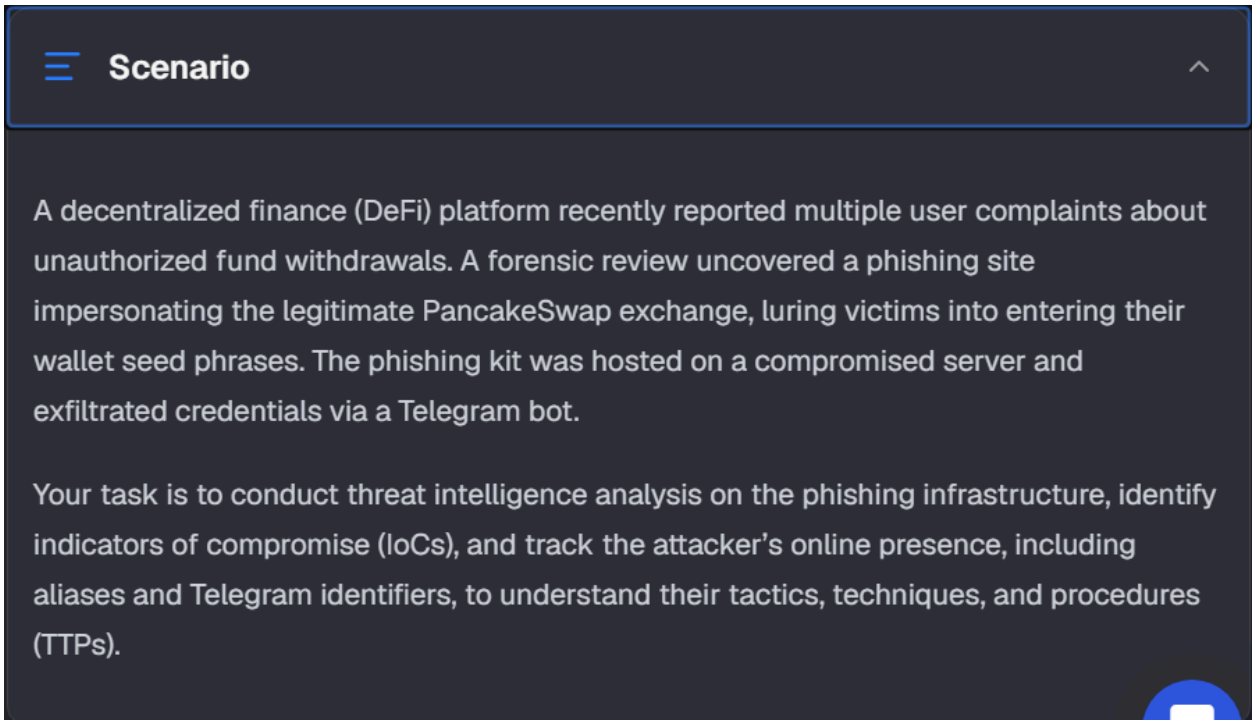
GrabThePhisher - CyberDefenders.org

Objective - to conduct threat intelligence analysis on the phishing infrastructure, identify indicators of compromise, and track the attacker.



Q1: Which wallet is used for asking the seed phrase?
Metamask - one of the folders in the phishing kit

Q2: What is the file name that has the code for the phishing kit?
Looked through the metamask directory using ls -la. I found a php file with the same name; this is gotta be it!
Metamask.php

Q3: In which language was the kit written?
Well…. php. Duh.

Q4: What service does the kit use to retrieve the victim's machine information?
I looked through the metamask.php file and it uses two specific APIs: Telegram and ***sypexgeo****. Considering that telegram is probably used to send the message, it had to have been sypexgeo, which after a google search turned out to be a fast, lightweight geolocation library and database tool that identifies a website visitor's country, region, city, and geographic coordinates based on their IP address.*

So the php gets the user's ip address, uses sypexgeo to retrieve other info about the user, collects the information (including the recovery phrase which is used to access the wallet) and uses the telegram API request to send all that info to the attacker. Finally, the recovery phrase is also saved locally into log.txt to obtain a second copy.

Q5: How many seed phrases were already collected?
*As the php code suggested, I went to log.txt. I found **3** rows 12 consecutive words, each row suggested it being a recovery phrase.*

Q6: what is the seed phrase associated with the most recent phishing incident?
I would think it is the last row: unless the attacker implemented a stack data structure for his collection of seed phrases; probably not.

Q7: which medium was used for credential dumping?
Telegram.

Q8: What is the token for accessing the channel?
It is clearly stated in the php script: albeit very long.

Q9: What is the Chat ID for the phisher's channel?
Also very clearly stated in the php script.

Q10: What are the aliases of the phish kit developer?
Also right there in the comment block in php.

DONE!

Takeaways:

- *This felt easier than my previous endeavors, but also very fun!*
- *Is it realistic to get this clear of an image of the phishing infrastructure to look at?*
- *Even as a still very nooby beginner, something tells me it will be never this simple and easy, with everything right there in front of me, only thing standing in between the truth and myself being the Kali Linux terminal.*
- *As much as AI agents/models will impact red-teaming and attacks, they will also help speed things up and make the blue team, investigative process much easier and less repetitive, which should be considered in making the work much more efficient, intellectual, and fun while maintaining the need for human intuition and validation.*